

Configuration Management Policy

Carraway Financial Bank (CFB)

Document Information

Policy Number	CFB-CM-001
Document Owner	Risk & Compliance Officer
Effective Date	03/03/2026
Last Review Date	N/A - Initial Release
Next Review Date	06/02/2026
Approved By	Chief Information Security Officer (CISO)

1. Purpose

The purpose of this policy is to establish standardized configuration baselines and monitoring practices to protect the integrity and security of Carraway Financial Bank's (CFB) systems. This policy ensures alignment with regulatory frameworks such as NIST SP 800-53 and PCI-DSS while minimizing the risk of unauthorized configuration changes.

2. Scope

This policy applies to all employees, contractors, and third-party vendors who manage or access Carraway Financial Bank (CFB) information systems. It covers all technology environments, including servers, databases, network devices, and the organization's managed cloud infrastructure.

3. Policy Statement

All Carraway Financial Bank (CFB) information systems must adhere to approved baseline configurations aligned with regulatory requirements. Unauthorized changes are strictly prohibited, and systems must be continuously monitored for configuration drift. Any deviations must be reverted to the baseline unless a formal exception is documented and approved by the Authorization Official.

4. Roles and Responsibilities

Chief Information Security Officer (CISO):

The Chief Information Security Officer serves as an advisor during the review of configuration-related requests and assists in determining the severity and potential impact of configuration issues. The CISO provides recommendations to stakeholders and the Authorization Official regarding compliance misconfigurations and whether exceptions or alternative solutions should be considered. **Authorization Official:** Responsible for the formal review and final approval of configuration exceptions and policy deviations.

System Owners:

System Owners are responsible for determining whether required security controls can be implemented within their systems. If a control cannot be fully met, System Owners must document and submit a request for an exception. They must justify the requested exception or alternative solution while coordinating with the IT Operations Team to address configuration issues affecting the system.

IT Operations Team:

The IT Operations Team is responsible for documenting configuration issues, notifying System Owners, and tracking requests from initiation through resolution. The team serves as the central point of contact for documenting findings, evaluating alternatives to exceptions, and ensuring that system configurations remain aligned with approved baseline standards.

Information Security Team:

The Information Security Team monitors system configuration settings daily and verifies alerts generated by the third-party configuration monitoring platform. The team acts as the first responder when configuration deviations occur, documents findings, and escalates issues to the IT Operations Team when further investigation or remediation is required.

5. Configuration Baseline Management

Baseline configurations must be established, documented, and maintained for all organizational systems, including servers, databases, network devices, cloud infrastructure, and applications. These baseline configurations define the approved security settings that systems must follow to maintain compliance with organizational security standards and regulatory requirements. Roles and responsibilities must be clearly defined to ensure that configuration drift or unauthorized changes are promptly identified and escalated. System Owners must be notified when configuration deviations occur so that appropriate corrective actions can be taken. All baseline configurations must be documented and maintained through the organization's change management and configuration management processes. Documentation must record configuration updates, system changes, and any actions taken during the investigation or remediation of configuration drift. Baseline configuration may be updated when approved system changes occur, when responsibilities are transferred between teams and personnel, or when updates are required to maintain compliance with evolving security standards. Servers and other critical infrastructure must be continuously monitored to protect sensitive data and support data protection practices such as Data Loss Prevention (DLP). Configuration monitoring platforms must be appropriately configured to align with business operations while ensuring compliance with security and regulatory standards. These platforms should support the identification of configuration drift without disrupting legitimate business functions.

6. Configuration Change Management

All configuration changes must follow the organization's formal change management process. Requests for configuration changes must be submitted and documented before implementation. Proposed changes must be reviewed to ensure they align with organizational security standards and do not introduce new security risks. Before a configuration change is implemented, the proposed change must be reviewed and approved by the appropriate System Owner and relevant security personnel. Testing and analysis must be conducted to confirm that the change will not negatively impact system security, system functionality, or regulatory compliance requirements. Once approved, configuration changes must be implemented through established procedures and properly documented. All implemented changes must be monitored to ensure they operate as expected and do not cause configuration drift or security vulnerabilities. If a configuration requirement cannot be met, an exception request must be submitted to the Authorization Official. Exception requests must include justification, documentation of attempted alternative solutions, and evidence that appropriate testing and risk analysis were conducted. Configuration changes and approved exceptions must be reviewed periodically to ensure continued compliance with organizational security standards. Reviews should occur quarterly, annually, and whenever significant system changes or new risks affecting the system or monitoring platform are identified.

7. Monitoring and Compliance

Configuration settings must be continuously monitored to detect configuration drift, unauthorized changes, or compliance deviations. Monitoring will be performed through the automated configuration monitoring platform, which alerts analysts when deviations from the approved baseline are detected. When alerts are generated, analysts must review the detected change to determine whether it represents an authorized modification, a false positive, or an unauthorized configuration change. If the change is determined to be unauthorized or introduces compliance concerns, escalation procedures must be followed to ensure the issue is properly documented and remediated. Regular monitoring and analyst verification ensure that configuration baselines remain accurate and aligned with the organization's security standards and regulatory requirements.

8. Exceptions

Policy exceptions may be requested when a system cannot meet an established configuration requirement. The appropriate System Owner must first review exception requests to determine whether the exception is necessary and whether alternative solutions are available. If an exception is deemed necessary, the request must be documented and communicated to the Information Security Team. The request must then be escalated to the Authorizing Official for formal review and approval. All exception requests must include documentation describing the reason for the exception, actions taken before the request, and the potential impact on system security. Approved exceptions must be documented and continuously monitored to ensure that the risk remains within the organization's acceptable risk tolerance.

9. Enforcement

Failure to comply with this policy may result in disciplinary action in accordance with organizational policies and procedures. Non-compliance may require additional training, corrective action, or further review to ensure that configuration management requirements are properly understood and followed. If repeated violations occur or if actions are found to be intentional or malicious, disciplinary measures may include a formal investigation, suspension of system privileges, or termination of employment, in accordance with organizational policies and applicable laws. All policy violations must be documented and reviewed to determine the cause of the incident and to implement corrective actions that prevent future occurrences.

10. Policy Review

This policy must be reviewed periodically to ensure that it remains aligned with organizational security requirements, regulatory obligations, and evolving cybersecurity risks. The policy should be reviewed on a quarterly and annual basis and updated whenever significant system changes occur, new systems are introduced, compliance requirements change, or new risks affecting the organization are identified. All updates to the policy must be documented and approved through the organization's policy governance process.

Approval and Authorization

Name	Title	Signature	Date
Mea Clift	Chief Information Security Officer / Authorization Official		
Adaeze Udoh	Chief Information Officer		
Mike Francer	IT Operations Director		
Tia Mitchell	Risk & Compliance Officer	Tia Mitchell	03/04/2026